U.PORTO
FACULDADE DE CIÊNCIAS
UNIVERSIDADE DO PORTO

ASSIGNMENT #2: PRIVACY IMPACT ASSESSMENT
SECURITY AND PRIVACY

Daniel Gomes 202306411
Inês Castro 202304060
Soraia Costa 202305078

Index

1. Introduction……..3

2. Describe/characterize the system setup that is the subject of this PIA……4

3. Initial risk assessment for a plain setup without any corrective measures……6

4. A plan of action (correction measures) to address the identified risks……..9

5. Risk assessment for an improved setup with application of corrective measures. Assessment/evaluation of the evolution of the risks with the corrective measures……...13

6. Conclusion……..……15

7. References……16

1) Introduction

As part of the curricular unit, we were asked to prepare a Privacy Impact Assessment (PIA) that will be applied to the real-world project: "COP-MODE", in which data was collected from several people about their use of smart devices. In this case, we are the PII controller/processor, responsible for determining the purposes and means of processing personal data.

According to NIST SP 800-53, a Privacy Impact Assessment (PIA) is an evaluation of how personally identifiable information (PII) is managed to ensure compliance with privacy regulations, to identify potential privacy risks, and to explore mitigation strategies.

Under the GDPR (General Data Protection Regulation), a PIA must include:

-A detailed explanation of the planned data processing activities and their purposes, including any legitimate interests of the data controller.

-An evaluation of whether the data processing is necessary and proportionate to its intended goals.

-An assessment of potential risks to individuals' rights and freedoms.

-Proposed measures to address those risks, such as safeguards and technical or organizational security controls to ensure data protection and GDPR compliance.

Importantly, a PIA doesn't just describe potential impacts; it evaluates privacy risks and proposes risk management strategies. At its core, the PIA process involves analyzing which PII is collected, processed, stored, or transmitted, identifying possible threats, and determining the resulting privacy impacts and necessary protective actions.

Figure 1 - General approach for carrying out a PIA

On the other hand, what is COP-MODE? What is it about? How was it prepared? By whom? What is its purpose?

COP-MODE (COntext-aware Privacy protection for MObile DEvices) is a research project of the University of Coimbra, University of Porto, University of Cambridge and INESC TEC, more specifically of the team: Ricardo Mendes and Mariana Cunha, PhD students at

the University of Coimbra; João Vilela (PI), professor at the University of Porto and Alastair Beresford (Co-PI), professor at the University of Cambridge.

This project started from the following problem: smart devices continuously collect vast amounts of data about our daily lives. Although this information originates from us, it is often owned and controlled by the companies that collect it, usually through our consent. While initiatives like the General Data Protection Regulation (GDPR) have made significant strides in regulating the collection and processing of personal data, individuals still have limited control over how their information is used. To challenge this imbalance, we need privacy-preserving technologies that return control to the users and protect their rights, which is the main purpose of COP-MODE.

Thus, based on data from a group of users through data collection campaigns, in COP-MODE the objective is to develop a privacy manager that is automatic, since automation reduces warning fatigue and intrusiveness generated by constant permission prompts; context-aware, since privacy is completely influenced by context, and personalized, since privacy is subjective.

2) Describe/characterize the system setup that is the subject of this PIA:

The COP-MODE project aims to enhance the privacy of mobile users by developing a privacy manager that gives users real-time control over app permissions. This tool intercepts permission requests made by any app to the operating system and prompts the user to approve or deny access based on the context at that moment. To improve usability, decisions for a given app and permission are temporarily cached for 30 minutes to reduce repetitive prompts.

To support the development of this system, data collection campaigns will be conducted with the help of volunteers. At the end of the campaign, each participant will receive a gift card as a token of appreciation. All collected data will be anonymized before being made available to researchers, ensuring participant privacy. To be eligible for participation, individuals must be Android users and 18 years or older.

Regarding the data collection campaign, it has several stages:

-Recruitment: The campaign begins with participant recruitment, typically announced through an email list. Interested users are instructed to download the COP-MODE Apps Retriever (CM-AR) from the Play Store.

–Running CM-AR: Once installed, participants follow the app's instructions. CM-AR sends the user's email and a list of installed apps (along with their permissions) to the project server. Only app names are collected—no internal app data such as messages or contacts is accessed.

The email is used strictly for communication during the campaign and is deleted afterward to ensure anonymity. The list of apps helps the COP-MODE team configure the campaign smartphone with the user's personal apps.

- Smartphone Setup and Handover: Based on the collected data, the team sets up a campaign smartphone pre-installed with the participant's apps and the COP-MODE Naive

Permission Manager (CM-NPM). The user receives an email to pick up the device and signs a data collection agreement upon receiving it.

-Data Collection Phase (1 week): For one week, participants use the campaign device as their main phone. During this period, CM-NPM prompts users in real time to allow or deny app permission requests. These responses, along with contextual data from both the user and the device, are collected and sent to the COP-MODE server.

-Campaign Conclusion and Reward: At the end of the week, the participant is notified via email. After returning the smartphone, they receive a voucher as a reward for their participation.

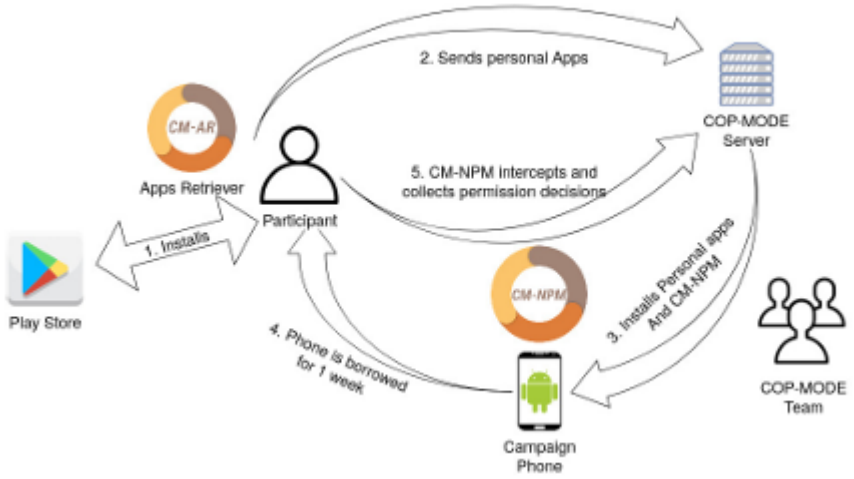

Figure 2 - COP-MODE Campaigns Methodology

What PII is collected/processed?

- Email Address (valid for one week, corresponding to the campaign week);

Instantaneous Data:

- List of installed apps on the smartphone and their respective permissions settings;*
- Calendar entries (calendar identifiers, their location, and start and end dates);*
- Connection type (Wi-Fi, 4G);
- Device operation.

Continuous Data:

- Geographic location;*
- Nearby devices.*

Permission Data:

- App information (*name, version, category, visibility);
- User decisions;
- User input (Semantic Location).

(* data deemed sensitive)

Which PII principals are affected?

The **data subjects** in this project are the participants who voluntarily provide their personal information. This data is collected, processed, and stored by the PII controller/processor and includes certain **sensitive information**, indicated with an asterisk (*).

What systems and processes are involved in handling PII?

- **Devices and Software**: Participants are provided with a loaned smartphone that comes pre-installed with their personal apps and the **COP-MODE permission manager**, which collects the required data for the study.

- **Data Collection**: Throughout the campaign, the system collects various types of data such as the list of installed applications, network connectivity type, contextual device information, calendar entries, location data, nearby device identifiers, and responses to permission prompts.

- **Data Management**: All collected data is stored and managed by the **COP-MODE team** at the University of Coimbra, following strict **privacy and security protocols**.

- **Data Sharing**: Anonymized and sanitized datasets may be shared with **academic research partners**, always under controlled and privacy-respecting conditions.

These systems and procedures aim to **safeguard participant privacy** while enabling research into improving mobile privacy through context-aware solutions. Participants maintain control over their personal data and can **request deletion at any time**.

3) Initial risk assessment for a plain setup without any corrective measures:

We want to minimize these 3 risks:

- illegitimate access to data;
- unwanted modification of data ;
- data disappearance.

However we already have planned or existing measures which are data minimization and anonymization and secure application development.

The level of risk is assessed based on two main factors: severity and likelihood.

- Severity reflects the extent or seriousness of the possible impact. It is mainly influenced by how harmful the consequences could be, considering aspects such as the type of personal data, the individuals affected, and the intended use of the data.

- Likelihood refers to the chance that the risk might materialize. This is largely determined by how exposed the system is to threats (its vulnerabilities) and how capable a threat actor is of taking advantage of those weaknesses.

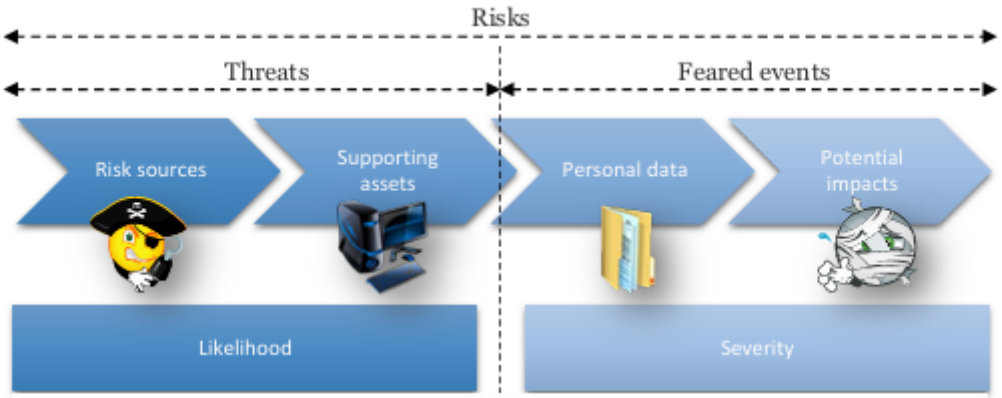

Figure 3- Risk components

We have developed the following privacy risk matrix for plain setup without any corrective measures:

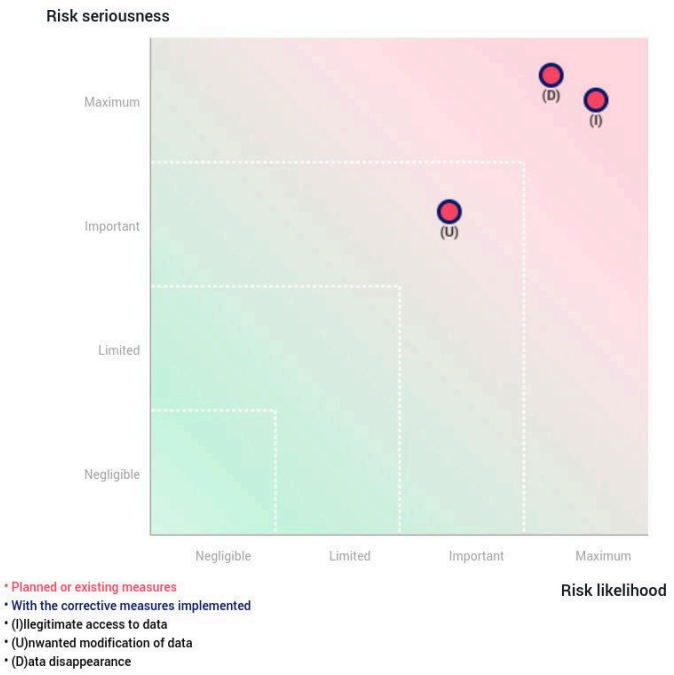

Figure 4 - Privacy risk matrix for plain setup without any corrective measures

From the privacy risk matrix above we conclude the following:

Risks	**Likelihood**	**Severity**
Illegitimate access to data	Maximum	Maximum
Unwanted modification of data	Important	Important
Data disappearance	Maximum	Maximum

Illegitimate Access to Data

- **Likelihood: Maximum** — The probability of this risk occurring is extremely high due to potential vulnerabilities in data transmission between smartphones and the COP-MODE server. Without robust encryption and secure communication protocols, unauthorized individuals could intercept the data.

- **Severity: Maximum** — The impact would be critical, leading to breaches of confidentiality, privacy violations, and legal consequences. This could compromise user trust, damage the project's reputation, and expose sensitive information.

Unwanted Modification of Data

- **Likelihood: Important** — The likelihood of accidental or intentional data modification is notable, especially considering the number of participants and data handling points throughout the project. Mistakes or unauthorized edits can occur during collection, storage, or analysis.

- **Severity: Important** — Although not as catastrophic as total data loss, the consequences include data corruption, flawed results, and resource-intensive correction processes. It can reduce the reliability of the project and delay its progress.

Data Disappearance

- **Likelihood: Maximum** — This risk has a very high chance of occurring, especially due to accidental deletions by users or researchers, system malfunctions, or security breaches that result in data being lost or erased.

- **Severity: Maximum** — The loss of collected data would be severely damaging. It could halt the project, cause noncompliance with ethical and legal standards, and potentially render weeks of research unusable. Data recovery may not be possible or may require substantial effort and cost.

4) A plan of action (corrective measures) to address the identified risks

Corrective measures:

Illegitimate Access to Data:

1. **End-to-End Encryption**
   Ensures that data is unreadable during transmission and storage unless decrypted by authorized parties, blocking unauthorized access even if data is intercepted.

2. **Access Control and Role-Based Permissions**
   Restricts data access based on user roles and responsibilities, ensuring only authorized personnel can view or manipulate sensitive data.

3. **Logging, Auditing, and Monitoring**
   Tracks access attempts and user actions, enabling detection of unauthorized access and supporting forensic analysis.

4. **Strong Authentication and Password Policies**
   Prevents unauthorized access through robust identity verification measures (e.g., multi-factor authentication, complex passwords).

5. **Firewalling and Network Segmentation**
   Limits exposure of data systems by isolating sensitive components and filtering out unauthorized traffic.

6. **Secure Third-Party Agreements and Assessments**
   Ensures third parties handling data also meet security requirements, preventing weak links in the data access chain.

7. **Data Minimization and Anonymization**
   Reduces the amount and identifiability of stored data, minimizing risk exposure even if data is accessed.

8. **Secure Application Development**
   Prevents application vulnerabilities that attackers could exploit to gain unauthorized access to data.

9. **Staff Training and Awareness**
   Reduces the risk of social engineering and insider threats by educating staff on

secure data handling practices.

10. **Incident Response and Contingency Plans**
    Provides a structured approach to detect, respond to, and mitigate access breaches quickly.

11. **Version Control and Change Management**
    Tracks and approves changes to systems handling data to prevent unauthorized access through unapproved modifications.

Unwanted Modification of Data:

1. **End-to-End Encryption**
   Ensures data cannot be tampered with during transmission without detection, preserving data integrity.

2. **Access Control and Role-Based Permissions**
   Prevents unauthorized users from editing or altering data by restricting write permissions.

3. **Logging, Auditing, and Monitoring**
   Detects unauthorized or accidental data changes and supports rollback or correction.

4. **Strong Authentication and Password Policies**
   Prevents unauthorized data changes by ensuring only verified users can make modifications.

5. **Firewalling and Network Segmentation**
   Reduces the attack surface, limiting attackers' ability to reach and tamper with data systems.

6. **Secure Third-Party Agreements and Assessments**
   Ensures partners follow standards that prevent accidental or intentional data modification.

7. **Data Minimization and Anonymization**
   Limits the scope of data that could be targeted or altered, reducing impact.

8. **Secure Application Development**
   Prevents exploits (e.g., injection attacks) that allow unauthorized data changes.

9. **Staff Training and Awareness**
   Helps prevent human errors or manipulation by educating staff on risks and procedures.

10. **Incident Response and Contingency Plans**
    Ensures a quick response to detect and reverse unwanted changes.

11. **Version Control and Change Management**
    Tracks changes and provides a rollback mechanism if unauthorized modifications occur.

Data Disappearance:

1. **Access Control and Role-Based Permissions**
   Prevents unauthorized deletion or movement of data by restricting who can perform such actions.

2. **Firewalling and Network Segmentation**
   Protects data from external attacks that might delete or corrupt it.

3. **Secure Third-Party Agreements and Assessments**
   Ensures external data handlers implement controls to prevent data loss or erasure.

4. **Logging, Auditing, and Monitoring**
   Detects anomalies or deletions quickly, enabling fast recovery.

5. **Regular Backups and Recovery Testing**
   Ensures data can be restored in case of loss, hardware failure, or attack.

6. **Staff Training and Awareness**
   Reduces accidental deletions and ensures proper backup handling.

7. **Data Integrity Mechanisms**
   Ensures stored data remains intact and uncorrupted over time.

8. **Secure Application Development**
   Prevents bugs or vulnerabilities that could cause data loss.

9. **Incident Response and Contingency Plans**
   Guides teams through the process of recovering lost data and restoring operations.

10. **Version Control and Change Management**
    Maintains historical data versions to restore deleted or overwritten information.

Risk	Mitigation
Data leak through eavesdropping of communications between smartphones and	End-to-End Encryption – ensures that data is encrypted both in transit and at rest.

the project server.	Firewalling and Network Segmentation – helps protect against unauthorized external access during communication. Secure Application Development – reduces security flaws that could allow interception.
Data leak from unauthorized server/data access. Access to the stored data should be limited to authorized users and the server should be accessible remotely, but not exposed/accessible directly to from the outside.	Access Control and Role-Based Permissions – restricts data access to authorized users only. Strong Authentication and Password Policies – prevents unauthorized access to the server. Firewalling and Network Segmentation – limits remote access to the server. Logging, Auditing, and Monitoring – allows detection and response to unauthorized access attempts.
Data at rest linkage. The data in the server should not be linkable to an individual by third parties. I.e. the email address must be protected (not clear text), but the PII collector/processor must still be able to link it to the data in the server (e.g. for deletion in case the participant requests it).	Data Minimization and Anonymization – removes direct identifiers such as names and emails. Data Integrity Mechanisms – ensures that data has not been altered during the anonymization process. Secure Third-Party Agreements and Assessments – imposes limits on who can view the data and how it can be used. End-to-End Encryption – protects data even when stored.
Sensitive information leakage, in particular the names of the applications that are collected. It is required to know that a given application was used and is the same for the several entries that are collected, but the names of the applications should not be present in the server in raw format.	Data Minimization and Anonymization – ensures that app names are not stored in plain text on the server. Secure Application Development – ensures sensitive data is handled carefully in the system's design. Logging, Auditing, and Monitoring – detects unauthorized access or extraction of application names. Data Integrity Mechanisms – detects

	unauthorized modifications to anonymized data.

5) Risk assessment for an improved setup with application of corrective measures. Assessment/evaluation of the evolution of the risks with the corrective measures using tool.

We have developed the following privacy risk matrix for plain setup with corrective measures:

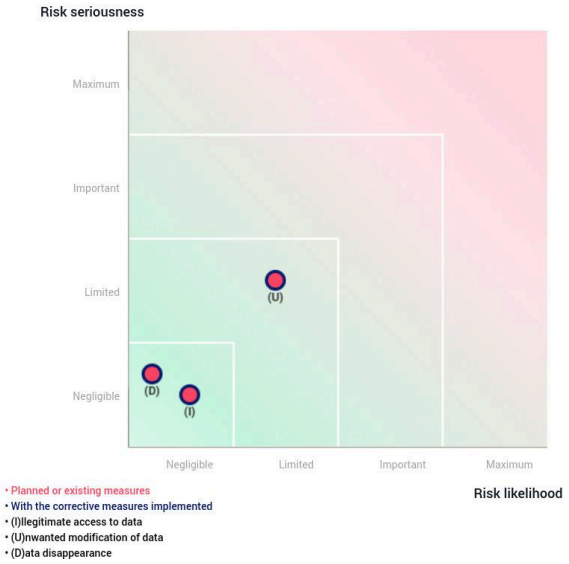

Figure 5- Privacy risk matrix for plain setup with corrective measures

From the privacy risk matrix above we conclude the following:

Risks	**Likelihood**	**Severity**
Illegitimate access to data	Negligible	Negligible
Unwanted modification of data	Limited	Limited
Data disappearance	Negligible	Negligible

Illegitimate access to data

- **Likelihood**: The likelihood of this threat is negligible due to robust access controls, data minimization practices, and strict authorization protocols. These measures significantly reduce the chances of unauthorized individuals gaining access to sensitive data.

- **Severity**: The severity is also negligible because the data is either encrypted or anonymized, making it practically useless to any unauthorized party who may attempt to access it without appropriate decryption keys or contextual knowledge.

Unwanted modification of data

- **Likelihood**: The likelihood of this threat is limited as there are monitoring processes, digital signatures, and human authentication systems in place. While these controls lower the risk, occasional human errors or targeted attacks might still succeed in modifying data.

- **Severity**: The severity remains limited because even if data is altered, backup systems and audit trails allow for swift detection and recovery. These mitigation strategies reduce the overall impact of the data modification.

Data disappearance

- **Likelihood**: The likelihood is negligible thanks to redundant data storage, regular backups, and fail-safe mechanisms designed to preserve data integrity. These systems ensure that data loss is an extremely rare occurrence.

- **Severity**: The severity is also negligible because even in the rare case of data disappearance, disaster recovery protocols and data restoration procedures ensure minimal disruption and full data recovery.

Conclusion

The Privacy Impact Assessment (PIA) for the COP-MODE project underscores the critical importance of integrating robust privacy safeguards into systems handling sensitive personal data. As a research initiative aimed at empowering mobile users through context-aware privacy management, COP-MODE inherently processes significant amounts of personally identifiable information (PII), necessitating rigorous compliance with GDPR principles and proactive risk mitigation.

The initial risk assessment identified three high-priority threats: illegitimate access to data, unwanted modification of data, and data disappearance, all rated with high values of likelihood and severity in a plain setup. These risks stemmed from vulnerabilities in data transmission, insufficient access controls, and inadequate backup mechanisms.

By implementing corrective measures such as end-to-end encryption, role-based access controls, regular backups, and data anonymization, the project successfully reduced these risks to negligible or limited levels. Enhanced monitoring, secure application development practices, and staff training further fortified the system against potential breaches. The revised risk matrix demonstrates a marked improvement, aligning the project with GDPR requirements and ensuring that participant data remains secure, confidential, and integral.

This PIA highlights the value of continuous evaluation and adaptive risk management in privacy-sensitive projects. By prioritizing technical safeguards, organizational protocols, and user-centric design, COP-MODE not only advances research in mobile privacy but also sets a precedent for ethical data handling in academic and technological initiatives. Future efforts should maintain this proactive stance, incorporating regular audits and updates to address evolving threats, thereby sustaining user trust and regulatory compliance.

References

[1] William Stallings, “Information Privacy Engineering and Privacy by Design”, Pearson Addison-Wesley, 2020

[2] Guidelines and software for PIA

[3] CNIL PIA tool. Tutorial video: https://www.youtube.com/watch?v=5J3h9zIFVDo

[4] Statistics New Zealand, “Privacy Impact Assessment for the Integrated Data Infrastructure”, 2012. https://www.stats.govt.nz/assets/Uploads/Retirement-of-archive-website-project-files/Privacy-Impact-Assessment/Privacy-impact-assessment-for-the-Integrated-Data-Infrastructure/idi-privacy-impact-assessment.pdf

[5] E.U. Smart Grid Task Force, “Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems”, September 2018, https://energy.ec.europa.eu/topics/markets-and-consumers/smart-grids-and-meters/data-protection-impact-assessment-smart-grid-and-smart-metering-environment_en

[6] COntext-aware Privacy protection for MObile DEvices https://cop-mode.dei.uc.pt R. Mendes, M. Cunha, J. P. Vilela, A. Beresford 2019-2020

[7]Effect of User Expectancy on Mobile App Privacy: A Field Study. R. Mendes, A. Brandão, J. P. Vilela, A. Beresford. International Conference on Pervasive Computing and Communications (PerCom), 2022

[8]Prediction of Mobile App Privacy Preferences with User Profiles via Federated Learning. A. Brandao, R. Mendes, J.P. Vilela, ACM Conference on Data and Application Security and Privacy (CODASPY), 2022

[9]Efficient Privacy Preserving Distributed K-Means for Non-IID Data. A. Brandão, R. Mendes, J.P. Vilela, Symposium on Intelligent Data Analysis, 2021